



IDENTITY & ACCESS

Access Control & Identity Management Policy

Defines least privilege, RBAC, password standards, and administrative access — all implemented via WorkOS.

Authentication, RBAC, and password complexity are delegated to WorkOS (SOC 2 Type II). This policy documents the Masar Zero configuration of WorkOS and the basic controls applied on founder laptops. Masar Zero does not run its own identity infrastructure or MDM.

PREPARED BY	Masar Zero W.L.L.
DOCUMENT ID	MZ-POL-003
VERSION	v1.0
EFFECTIVE	12 July 2026
CLASSIFICATION	Internal Use — Authorized Recipients Only

Document Control

Document ID	MZ-POL-003	Version	v1.0
Effective Date	12 July 2026	Review Cycle	Annual (next review: July 2027)
Document Owner	Hari Krishna	Classification	Internal Use
Publisher	Masar Zero W.L.L.	Contact	hari@masarzero.com

Revision History

Version	Date	Author	Summary of Change
v1.0	12 July 2026	Masar Zero	Initial release of Access Control & Identity Management Policy.

Approval

This document is prepared by Hari Krishna and approved by Dr. A. Latif Alkhaja, Chairman of Masar Zero W.L.L. It is effective as of the date shown above and is reviewed annually or upon significant change per MZ-POL-001 §7. Distribution is restricted to authorized recipients; redistribution requires written approval from Masar Zero leadership.

Role	Name	Signature	Date
Prepared by	Hari Krishna		
Approved by	Dr. A. Latif Alkhaja (Chairman)		

1. Purpose & Scope

This policy defines the controls Masar Zero W.L.L. applies to manage user identities, enforce least privilege, implement role-based access control (RBAC), and enforce strong password-based authentication. It applies to all Masar Zero founders, operators, and automated service accounts.

Authentication, RBAC enforcement, and password complexity are operationally delegated to WorkOS, which holds SOC 2 Type II attestation. Masar Zero does not operate its own password store or identity database. This policy documents the Masar Zero configuration of WorkOS and the basic controls Masar Zero applies on founder laptops. The WorkOS trust page (<https://workos.com/security>) is the authoritative source for platform-level controls.

2. Identity Lifecycle

Every human identity that can access Masar Zero cloud resources is provisioned, authenticated, and deprovisioned by WorkOS. The identity lifecycle is:

- **Provisioning:** A new founder or operator joins — an existing founder creates a WorkOS account with the minimum role required. The account is created with a one-time invitation link that expires in 24 hours.
- **Authentication:** The user authenticates with WorkOS using their email + password + TOTP MFA token. SSO via Google Workspace is also supported for founder accounts.
- **Modification:** Role changes are discussed by founders and actioned in WorkOS within 1 business day.
- **Deprovisioning:** On termination of access, a founder suspends the WorkOS account within 4 business hours. The account is hard-deleted (with audit retention) after 90 days.
- **Quarterly review:** Founders review all active WorkOS accounts quarterly and remove any that are no longer required.

3. Least Privilege

Masar Zero enforces least privilege at two layers: (a) WorkOS RBAC restricts which application features each role can access; (b) Supabase row-level security policies restrict which database rows each role can read or write. The combined effect is that each user can perform only the actions explicitly required for their role.

Default access for a new operator is the *Operator* role (read-only dashboard + view HMI mirror). Elevated access requires a separate role assignment. Standing privileged access is limited to founders in the *Administrator* role.

4. Role-Based Access Control (RBAC)

WorkOS RBAC is configured with three roles, mapped to job functions. Each role has a defined permission set; permissions are granted to roles, never to individual users.

Role	Job Function	Permissions
Operator	Operations staff — monitor VRU	View dashboard; pull live PLC telemetry on-demand (read-only).
Supervisor	Senior operator — manage shift	All Operator permissions + export hourly aggregate reports.
Administrator	Founder	All Supervisor permissions + manage WorkOS users; configure WeCon box; access Supabase console; manage Vercel deployment.

Table 1 — Masar Zero RBAC role-permission matrix.

5. Password-Based Authentication

Password complexity, length, and lifespan are enforced by WorkOS per its platform defaults. Masar Zero does not run its own password store. The WorkOS platform documentation at <https://workos.com/docs/user-management/passwords> is the authoritative source for these settings. MFA (TOTP per RFC 6238) is mandatory for all roles. Hardware security keys (WebAuthn) are supported by WorkOS and recommended for founder accounts.

Founder credentials for non-WorkOS systems (Vercel, Supabase, Google Workspace, GitHub, WeCon cloud, 1Password) are stored in 1Password. Founder accounts on all subprocessor platforms require 2FA.

6. Administrative Machines

Administrative tasks — defined as any task requiring the Administrator role in WorkOS, the Supabase admin console, the Vercel dashboard, or the WeCon cloud console — are performed only from Masar Zero founder laptops. Masar Zero does not maintain dedicated administrative machines. Founder laptops use built-in disk encryption (FileVault on macOS, BitLocker on Windows) and OS auto-update. There is no MDM enrollment.

WeCon box configuration is performed only from the local HMI at the station or via the WeCon cloud console (founder laptop). Direct WeCon box access from any other machine is prevented by the air-gapped plant-floor network.

7. Service Accounts & API Keys

Automated integrations between Masar Zero components use service accounts with scoped API keys. Each service account has a documented owner (a founder), a defined scope, and a rotation schedule. Keys are stored in 1Password and in Vercel environment as encrypted secrets; they are never committed to source control. Founders review the service account register quarterly.

8. Access Review

Founders conduct a quarterly access review covering: (a) all WorkOS user accounts and their role assignments; (b) all service accounts and their API key validity; (c) all Supabase role assignments; (d) founder access to each subprocessor admin console. The review is documented in a Google Sheet; any discrepancies are remediated within 5 business days.

9. References

- WorkOS Security & Compliance — <https://workos.com/security>
- WorkOS Password Management Documentation — <https://workos.com/docs/user-management/passwords>
- WorkOS MFA Documentation — <https://workos.com/docs/user-management/mfa>
- BAPCO-QR-001 — Master Questionnaire Response §6.3
- MZ-POL-001 — Cybersecurity & Data Protection Governance Program

MZ-POL-003 — Access Control & Identity Management Policy. End of document.